# Phishing-Certificate-Analyzer

Fall 2026

Keegan Hamp, Chase Hunnicutt, Jackson Fulks
Project Group 7

*All screenshots will be using the website “amazon.com” for an example *

## Overview

This project shows a way to analyze the security of a website connection. It analyzes both TLS certificates and common phishing techniques to evaluate possible security risks associated with a website. The tool examines certificate information such as validity dates, hostname matching, public key strength, signature algorithms, certificate trust, and supported TLS versions. It also analyzes the website’s domain and webpage for indicators commonly associated with phishing, including misleading subdomains, Punycode, brand lookalikes, suspicious keywords, insecure password forms, and potentially unsafe links.

After completing these checks, the program generates a report containing its findings and separate risk scores for the website’s certificate configuration and domain indicators. These scores are not intended to determine with certainty whether a website is safe or malicious. Instead, the tool brings multiple security indicators together into one report so that a user can more easily identify potential weaknesses or signs that require further investigation.

## Project Goals

1. Analyze a website’s TLS connection for certificate and cryptographic security issues.
2. Identify common phishing indicators in the website’s domain and static webpage content.
3. Detect risks such as expired or mismatched certificates, weak cryptographic settings, misleading domains, suspicious links, and insecure password forms.
4. Present the findings in a clear report with separate certificate and domain risk scores.
5. Demonstrate the difference between a technically valid TLS connection and a website that may still show signs of phishing.

# System Design

The system is designed as a command-line website security analyzer written in Python. A user provides either a domain name or an HTTPS URL, and the program validates the input before performing several separate security checks. In a normal analysis, the program retrieves the website's TLS certificate and certificate chain, verifies certificate trust, checks supported TLS versions, analyzes the domain for phishing indicators, and tries to get and inspect the static HTML format of the website for suspicious link destinations, insecure password forms, and HTML refresh commands and then reports the HTTP redirect without explicitly going to the new page . The results are then organized into terminal tables that display certificate information, warnings, and separate certificate and domain risk scores.

The program also supports a domain-only mode that performs phishing-related domain checks without creating any network connections. This allows a suspicious hostname to be reviewed without retrieving certificates or webpage content.

## TLS and Certificate Analysis

The TLS portion of the program first creates a connection to the target server and retrieves the certificate, the certificate chain supplied by the server, the negotiated TLS version, and the selected cipher. The first connection does not perform normal certificate verification because the analyzer must still be able to retrieve and inspect a certificate even when that certificate is invalid or misconfigured.

After retrieving the certificate, the program extracts information such as the issuer, validity dates, alternative DNS names, signature algorithm, public key type and size, and whether the certificate appears to be self-signed. The analyzer then checks for problems including expired certificates, certificates that are not yet valid, hostname mismatches, self-signed certificates, RSA keys smaller than 2048 bits, elliptic-curve keys smaller than 256 bits, and certificates using MD5 or SHA-1 signatures.

A separate TLS connection is used to perform normal certificate trust verification. This determines whether the certificate can be validated using Python's trusted certificate authorities and hostname checking. The result is reported as Passed, Failed, or Inconclusive. The program also performs separate connection attempts using TLS 1.2 and TLS 1.3 to determine whether those protocol versions can be successfully negotiated with the server.

*Certificate Chain Sent by Server*

| # | Subject | Issuer | Expires (UTC) |
|---|---|---|---|
| 1 | CN=*.peg.a2z.com | CN=GeoTrust TLS RSA CA G1,OU=www.digicert.com,O=DigiCert Inc,C=US | 2027-04-05 23:59 |
| 2 | CN=GeoTrust TLS RSA CA G1,OU=www.digicert.com,O=DigiCert Inc,C=US | CN=DigiCert Global Root G2,OU=www.digicert.com,O=DigiCert Inc,C=US | 2027-11-02 12:23 |
| 3 | CN=DigiCert Global Root G2,OU=www.digicert.com,O=DigiCert Inc,C=US | CN=VeriSign Class 3 Public Primary Certification Authority - G5,OU=(c) 2006 VeriSign\, Inc. - For authorized use only,OU=VeriSign Trust Network,O=VeriSign\, Inc.,C=US | 2028-04-02 23:59 |

This table shows the certificates supplied by the server. See Certificate verification for the separate trust-check result.

*TLS Version Checks*

| Version | Result | Details |
|---|---|---|
| TLS 1.2 | Supported | Negotiated TLSv1.2. |
| TLS 1.3 | Supported | Negotiated TLSv1.3. |

The analyzer displays the server certificate chain, including each certificate's subject, issuer, and expiration date. Different connection tests confirm that the server accepts TLS 1.2 and TLS 1.3.

## Phishing and Domain Analysis

The domain analysis portion looks for characteristics that may indicate phishing or impersonation. These checks are heuristic and are not intended to prove that a domain is malicious. The program identifies cases where an IP address is used instead of a domain, detects Punycode, checks for suspicious keywords such as login, verify, account, secure, and update, and looks for simple digit substitutions that resemble known brands.

The analyzer also separates the hostname into its registered domain, subdomain, and public suffix. This allows it to detect misleading addresses where a trusted brand name appears in a subdomain even though the actual registered domain belongs to another site. For example, in paypal.com.example.org, the registered domain is example.org while paypal.com is only part of the subdomain.

## Webpage Analysis

The webpage analysis examines the static HTML returned by the target site. It does not execute JavaScript, follow links, download files, or submit forms. Instead, it parses the page for links, scripts, iframes, forms, password fields, and HTML refresh directives.

The analyzer checks linked destinations using the same domain-analysis rules, identifies executable download links, flags HTTP references, and reviews password forms for security problems. Password forms are flagged if they submit over HTTP, submit to another

hostname, or do not use the POST method. HTML refresh redirects are also reported for review. These webpage findings are informational and do not contribute points to the certificate or domain risk scores.

| Field | Value |
|---|---|
| Hostname | amazon.com |
| Port | 443 |
| Registered domain | amazon.com |
| Subdomain | None |
| Public suffix | com |
| Issuer | CN=GeoTrust TLS RSA CA G1,OU=www.digicert.com,O=DigiCert Inc,C=US |
| Certificate domain names | amazon.co.uk, uedata.amazon.co.uk, www.amazon.co.uk, origin-www.amazon.co.uk, *.peg.a2z.com, amazon.com, amzn.com, uedata.amazon.com, us.amazon.com, www.amazon.com, www.amzn.com, corporate.amazon.com, buybox.amazon.com, iphone.amazon.com, yp.amazon.com, home.amazon.com, origin-www.amazon.com, origin2-www.amazon.com, buckeye-retail-website.amazon.com, huddles.amazon.com, amazon.de, www.amazon.de, origin-www.amazon.de, amazon.co.jp, amazon.jp, www.amazon.jp, www.amazon.co.jp, origin-www.amazon.co.jp, *.aa.peg.a2z.com, *.ab.peg.a2z.com, *.ac.peg.a2z.com, origin-www.amazon.com.au, www.amazon.com.au, *.bz.peg.a2z.com, amazon.com.au, origin2-www.amazon.co.jp, edgeflow.aero.4d5ad1d2b-frontier.amazon.co.jp, edgeflow.aero.04f01a85e-frontier.amazon.com.au, edgeflow.aero.47cf2c8c9-frontier.amazon.com, edgeflow.aero.abe2c2f23-frontier.amazon.de, edgeflow.aero.bfbdc3ca1-frontier.amazon.co.uk, edgeflow-dp.aero.4d5ad1d2b-frontier.amazon.co.jp, edgeflow-dp.aero.04f01a85e-frontier.amazon.com.au, edgeflow-dp.aero.47cf2c8c9-frontier.amazon.com, edgeflow-dp.aero.bfbdc3ca1-frontier.amazon.co.uk, edgeflow-dp.aero.abe2c2f23-frontier.amazon.de, shop.business.amazon.com |
| Valid from | 2026-09-20 00:00:00+00:00 |
| Expires | 2027-04-05 23:59:59+00:00 |
| Days remaining | 165 |
| Negotiated TLS version | TLSv1.3 |
| Public key | RSA (2048 bits) |
| Signature algorithm | sha256WithRSAEncryption |
| Certificate verification | Passed |
| Verification details | Certificate verification succeeded. |

The picture above shows the checks performed by the analyzer.

## Risk Scoring

The program uses a rule-based scoring system to summarize the findings. Certificate-related findings and domain-related findings are scored separately, with each score capped at 100. Certificate points are assigned to issues such as expiration, hostname mismatch, weak key sizes, and weak signature algorithms. Domain points are assigned to indicators such as raw IP addresses, Punycode, suspicious keywords, brand lookalikes, and misleading subdomains. The final report displays a certificate configuration score and a domain indicator score. Verification failures and webpage findings are shown separately and do not add points in order to avoid double-counting or overestimating risk. The scores represent the checks implemented by the program and are not intended to represent the probability that a website is phishing or safe.

| Assessment | Score |
| --- | --- |
| Certificate configuration | 0/100 |
| Domain indicators | 0/100 |

This shows the risk score associated with amazon.com specifically.

# Testing and Results

## Automated Testing

The project includes an automated test suite written with `pytest`. The current test file contains 17 tests that verify selected behaviors of the certificate, domain, webpage, and TLS-analysis functions. These tests use sample data and mocked network behavior so that many checks can be validated without depending on live websites.

The tests cover several important functions of the analyzer. Certificate-related tests confirm that a certificate whose validity period has not started is shown and assigned the risk points. Domain-analysis tests check Punycode decoding, suspicious keywords, raw IP addresses, brand lookalikes, and misleading subdomains. Webpage-analysis tests verify that suspicious links, executable download links, insecure password forms, and HTML refresh redirects are identified correctly. The test suite also simulates TLS connection failures and confirms that the `--domain-only` mode avoids making network connections.

These automated tests help verify that the implemented detection rules continue to behave as expected after changes to the program. They do not test every possible website, certificate configuration, or phishing technique, but they provide coverage for the major checks currently implemented.

## Test Cases and Observed Results

The analyzer was designed to be tested against multiple categories of targets, including legitimate websites, intentionally misconfigured certificate sites, and simulated phishing examples. The report produced by the program includes certificate details, certificate verification results, TLS 1.2 and TLS 1.3 checks, domain findings, webpage findings, and separate certificate and domain scores.

For simulated phishing cases, the automated tests demonstrate that the program can identify examples such as `paypa1.example` as a possible PayPal lookalike and `paypal.com.example.org` as a misleading subdomain where the actual registered domain is `example.org`. The webpage tests also show that the analyzer can flag links to suspicious destinations and password forms that submit credentials over HTTP. The results produced by the analyzer should be interpreted as indicators for further review rather than definitive judgments. A low score does not prove that a website is safe and vice versa.

## Limitations

The current version of the analyzer is intended to identify security indicators rather than provide a complete determination of whether a website is malicious. Its findings are based on a limited set of certificate, domain, and webpage checks, so false positives and false negatives are possible. A low score does not guarantee that a website is safe, and a high score does not prove that the site is phishing.

The webpage analysis is limited to static HTML. The analyzer does not execute JavaScript, follow links, submit forms, or download and inspect linked files. Because of this, phishing techniques that depend on dynamically generated content or scripts may not be detected.

The program also does not use reputation databases, phishing blocklists, or certificate revocation checking. In addition, the TLS checks only test TLS 1.2 and TLS 1.3, while older versions such as TLS 1.0 and TLS 1.1 are not tested.

The domain analysis also uses a relatively small set of known brands and simple character-substitution rules. This means more advanced typosquatting, homoglyph attacks, or impersonation of brands that are not included in the reference list may not be detected. The current implementation specifically includes only a small set of brands such as PayPal, Google, Microsoft, Amazon, and Apple.

## Conclusion

This project demonstrates a practical method for analyzing several security aspects of a website in one tool. The analyzer combines TLS certificate inspection, certificate trust verification, domain-based phishing detection, TLS version checks, and static webpage analysis to identify possible security concerns. By combining these checks, the program provides more context than relying on HTTPS or certificate validity alone.

The project also demonstrates an important security concept: a valid TLS connection does not necessarily mean that a website itself is trustworthy. A phishing site may still use a valid

certificate and strong encryption while using a deceptive domain or suspicious webpage behavior. The analyzer addresses this by reviewing both the security of the connection and indicators that may suggest impersonation or phishing. Its results are intended to support further review rather than provide a definitive judgment of whether a website is safe or malicious.